Data Processing Agreement (GDPR / KVKK)

For the QRNot Digital Product Passport (DPP) service

> **DRAFT — LEGAL REVIEW REQUIRED.** This text is a template. It must be reviewed by a lawyer and the fields in square brackets [ ] completed before signing. Because data is processed in the USA, where the customer is subject to the GDPR the Standard Contractual Clauses must be attached in full; where Turkish KVKK applies, the standard contract published by the Turkish Personal Data Protection Board must be used verbatim and notified to the Authority within the statutory period.

---

1. Parties

Controller ("Customer"): [Company name], [address], [registration / VAT number]

Processor ("QRNot"): SCE INNOVATION LTD. ŞTİ., Çetin Emeç Bulvarı 25/3, Çankaya, Ankara, Türkiye, [tax / registration number]

This agreement is an annex to the QRNot DPP service agreement between the parties dated [date] (the "Main Agreement"). In case of conflict on matters of personal data protection, this agreement prevails.

2. Definitions

Terms such as "personal data", "processing", "controller", "processor", "data subject" and "personal data breach" have the meaning given in Regulation (EU) 2016/679 ("GDPR") and, where applicable, Turkish Law No. 6698 on the Protection of Personal Data ("KVKK").

3. Subject matter, duration, nature and purpose

1. QRNot processes personal data on behalf of the Customer solely to provide the DPP service under the Main Agreement.
2. Nature of processing: hosting, storage, display, user authentication, statistics and (when requested by the Customer) automatic translation.
3. Duration: for the term of the Main Agreement and until the return/deletion process in section 9 is completed.
4. Categories of data and data subjects are set out in **Annex 1**.

4. Customer obligations

1. The Customer is responsible for the lawfulness of the personal data it provides to QRNot, including providing information notices and obtaining consent where required.
2. The Customer takes care not to enter personal data in the public sections of a passport and is responsible for the information published there.
3. The Customer shares the authorised-access key and supplier links only with authorised persons.

DRAFT

5. QRNot obligations

1. **Instructions:** QRNot processes personal data only on the Customer's documented instructions (including the Main Agreement, this agreement and actions taken in the panel). QRNot informs the Customer without delay if it considers an instruction to infringe applicable law.
2. **Confidentiality:** QRNot staff and contractors with access to personal data are bound by confidentiality.
3. **Security:** QRNot implements the technical and organisational measures in **Annex 2**. Measures may be updated in line with technical progress provided the level of security is not reduced.
4. **Data subject requests:** QRNot reasonably assists the Customer in responding to requests under GDPR Articles 15–22 / KVKK Article 11, and forwards any request it receives directly.
5. **Personal data breach:** QRNot notifies the Customer without undue delay and no later than [48] hours after becoming aware of a breach affecting Customer data, describing its nature, the categories of data concerned, likely consequences and measures taken. Notification to supervisory authorities and data subjects is the Customer's responsibility as controller; QRNot assists.
6. **Records:** QRNot maintains the records of processing required of a processor.
7. **Assistance:** QRNot reasonably assists the Customer with data protection impact assessments and prior consultations relating to the service.

6. Subprocessors

1. The Customer gives general authorisation for the subprocessors listed in **Annex 3**.
2. QRNot informs the Customer in writing (email sufficient) at least [30] days before adding or replacing a subprocessor. The Customer may object on reasonable grounds within that period; if the objection cannot be resolved, the Customer may terminate the affected service without penalty.
3. QRNot imposes on subprocessors data protection obligations that are substantially the same as in this agreement and remains liable to the Customer for their performance.

7. International transfers

1. The parties acknowledge that the service infrastructure is located in the USA (Annex 3) and that personal data is therefore transferred outside the EU/EEA and Türkiye.
2. **GDPR:** Where the Customer is established in the EU/EEA or subject to the GDPR, transfers are made under the **Standard Contractual Clauses** adopted by Commission Implementing Decision (EU) 2021/914, **Module 2 (controller to processor)**, which are attached and form an integral part of this agreement. Docking clause: [yes/no]; Clause 9 option: general authorisation, [30] days; Clause 13: [competent supervisory authority]; Clauses 17–18: [law and courts of an EU Member State].
3. **KVKK:** Where Turkish law applies, transfers are made under the **standard contract** published by the Turkish Personal Data Protection Board (controller-to-processor module), signed separately and notified to the Authority within the statutory period.
4. **EU region option:** At the Customer's request and on terms to be agreed, the database and files can be moved to an EU region (e.g. Frankfurt). Annex 3 is then updated.

8. Audits

1. QRNot makes available the information necessary to demonstrate compliance with this agreement and answers the Customer's security questionnaires within a reasonable time.

DRAFT

2. The Customer may audit at most once a year, with at least [30] days' written notice, at its own cost and through an auditor bound by confidentiality. Audits of infrastructure providers' facilities are satisfied by the independent audit reports and certifications those providers publish.

9. Termination: return and deletion

1. On termination of the Main Agreement, QRNot hands over product data, documents and serial numbers in machine-readable form (JSON / CSV and files) at the Customer's request.
2. As published passports may need to remain available while products are on the market, the parties agree in writing on one of: (a) keeping published passports online for a further [X] years for a separate fee, (b) a transition period for migration to the Customer's own infrastructure, or (c) deletion.
3. At the end of the agreed period, personal data is deleted or anonymised within [90] days, except where retention is required by law, and this is confirmed to the Customer in writing. Copies in backups are deleted within the backup cycle.

10. Liability and miscellaneous

1. Each party's liability under this agreement is subject to the liability provisions of the Main Agreement, [without prejudice to liability for intent and gross negligence].
2. This agreement is governed by [Turkish law]; [Istanbul] courts have jurisdiction. Where the SCC are attached, their governing-law and jurisdiction clauses prevail for the SCC.

Annex 1 — Details of processing

Item	Description
Data subjects	The Customer's panel users (employees); contact persons at the Customer's suppliers; persons the Customer names in passports (e.g. manufacturer / importer contact)
Categories of personal data	Identity (name), contact (email, phone — if entered), user activity (role, last login time, email of the user who published), name / email in supplier responses and any personal data contained in documents uploaded by suppliers
Passport scans	The scanning person's IP address is **not stored**. Only country code, language and time are kept for statistics; on their own these do not identify a person.
Special categories	Not intended. The Customer does not enter special-category personal data in the panel.
Purpose	Providing the DPP service: account management, authorisation, passport publishing, document storage, supplier data collection, translation, statistics
Retention	Term of the Main Agreement + the process in section 9

DRAFT

Annex 2 — Technical and organisational measures

Area	Measure
Encryption in transit	All traffic over HTTPS (TLS); HSTS enabled
Encryption at rest	The database provider (Neon) states that stored data is encrypted with AES-256
Passwords	Salted scrypt hash; never stored in plain text
Sessions	Random session token, stored only as a SHA-256 hash; httpOnly + secure cookie; 14-day validity
Login protection	Temporary lock after repeated failed logins; rate limits on panel and upload operations
Authorisation	Per-company data isolation (every query scoped to the signed-in company); owner / editor / viewer roles
Sensitive passport fields	Visible only with a rotatable "authorised-access key"
Files	Private storage; every access passes a server-side authorisation check
Supplier links	192-bit random, time-limited link; a supplier can access only their own request; nothing is copied into a product without the company's approval
Data minimisation	No IP stored for scans; only product texts are sent for automatic translation
Immutability	Each published passport is stored as an immutable version
Certifications	QRNot itself does **not** hold ISO 27001 / SOC 2 certification. Infrastructure providers publish their own certifications.

Annex 3 — Subprocessors

Subprocessor	Service	Location
Vercel Inc.	Application hosting, file storage (Vercel Blob)	USA
Neon Inc. (on Amazon Web Services)	PostgreSQL database	USA — AWS us-east-1
Anthropic PBC	Automatic translation (only when the Customer requests it; product texts)	USA

Controller (Customer) — Name / Title / Signature / Date

Processor (QRNot) — Name / Title / Signature / Date

DRAFT